Data Retention and Protection Policy

Transparency Hub Network Version: 1.0 **Effective Date:** March 5, 2026 **Last Updated:** March 5, 2026 **Owner:** Engineering Team **Classification:** Internal

---

1. Purpose

This policy defines how Transparency Hub Network collects, processes, stores, protects, retains, and disposes of data across all systems and services. It ensures compliance with applicable data protection regulations and establishes clear standards for safeguarding the personal and organizational data entrusted to us by our users.

---

2. Scope

This policy applies to:

- All personal data of members, administrators, and visitors
- All organizational data belonging to associations, chapters, and clubs
- All financial and payment data
- All meeting recordings, transcripts, and minutes
- All system-generated data (logs, analytics, audit trails)
- All environments: development, staging, and production
- All personnel, contractors, and third parties with access to data

---

3. Regulatory Framework

Regulation	Applicability	Key Requirements
Nigeria Data Protection Regulation (NDPR) 2019	Primary — Nigerian users and organizations	Lawful processing, consent, data minimization, breach notification within 72 hours, data protection officer appointment for large-scale processing
Nigeria Data Protection Act (NDPA) 2023	Primary — supersedes and strengthens NDPR	Enhanced data subject rights, cross-border transfer rules, mandatory data protection impact assessments
General Data Protection Regulation (GDPR)	International users (EU/EEA)	Lawful basis for processing, data subject rights, 72-hour breach notification, data protection by design
Payment Card Industry DSS (PCI DSS)	Payment processing	Delegated to PCI-certified processors (Stripe, Paystack)

---

4. Data Collection

4.1 Lawful Basis for Processing

We collect and process data under the following legal bases:

Basis	Description	Examples
Consent	User explicitly agrees to data processing	Account registration, email communications, meeting recording
Contractual Necessity	Processing required to fulfill a service agreement	Membership management, dues processing, event management
Legitimate Interest	Processing necessary for platform operation and security	Security logging, fraud prevention, service improvement
Legal Obligation	Processing required by law	Financial records retention, tax reporting, regulatory compliance

4.2 Data Minimization

- We collect only data that is necessary for the stated purpose
- Optional fields are clearly marked and not required
- Data collection forms are reviewed quarterly to remove unnecessary fields
- Third-party integrations receive only the minimum data required for their function

4.3 Consent Management

- Users provide explicit consent during account registration
- Consent for meeting recording is obtained through the admin's explicit toggle per event
- Consent preferences can be updated by users at any time through their account settings
- Withdrawal of consent is processed within 30 days
- Consent records are maintained for audit purposes

---

5. Data Categories and Classification

5.1 Personal Data Inventory

Data Category	Data Elements	Classification	Purpose	Retention
Identity Data	First name, last name, display name	Confidential	Member identification, communications	Duration of membership + 12 months
Contact Data	Email address, phone number, postal address	Confidential	Account access, notifications, communications	Duration of membership + 12 months
Account Data	Username, password (hashed), OTP preferences	Restricted	Authentication and access control	Duration of account existence
Profile Data	Date of birth, profile photo, bio, occupation	Confidential	Member profiles, directory	Duration of membership + 12 months
Membership Data	Membership type, status, chapter, join date, expiry date	Confidential	Membership management, renewals	Duration of membership + 24 months

Financial Data	Payment amounts, transaction IDs, payment status, dues records	Confidential	Dues management, financial transparency	7 years (regulatory)
Payment Credentials	Card numbers, bank details	Restricted	Payment processing	NOT stored — handled by Stripe/Paystack
Meeting Data	Meeting recordings (audio/video), transcripts, AI-generated minutes	Confidential	Meeting documentation, organizational transparency	12 months (recordings), indefinite (minutes — association decides)
Event Data	Event titles, descriptions, dates, meeting links, timezone	Internal	Event management	Duration of association + 12 months
Communication Data	Email notifications sent, notification preferences	Internal	Communication management	12 months
Technical Data	IP addresses, browser type, device information	Internal	Security, debugging, analytics	90 days
Usage Data	Feature usage, page views, session duration	Internal	Service improvement	90 days (aggregated data retained indefinitely)
Audit Data	Login history, data modifications, admin actions	Confidential	Security, compliance, accountability	1 year

5.2 Special Category Data

Transparency Hub Network does **not** intentionally collect special category data (racial/ethnic origin, political opinions, religious beliefs, health data, biometric data). If such data is incidentally captured in meeting recordings or transcripts, it is processed solely for the purpose of generating meeting minutes and is subject to the same protections as all Confidential data.

---

6. Data Retention Schedule

6.1 Retention Periods

Data Type	Active Retention	Archive Period	Total Retention	Disposal Trigger
Member personal data	Duration of active membership	12 months after membership ends	Membership + 12 months	Membership termination + 12 months

Account credentials	Duration of account existence	None — deleted immediately	Account lifetime	Account deletion
Membership records	Duration of membership	24 months after expiry	Membership + 24 months	Expiry + 24 months
Payment transactions	3 years (active reference)	4 years (archive)	7 years total	Transaction date + 7 years
Dues records	Duration of association membership	7 years after last transaction	7 years (regulatory)	Last transaction + 7 years
Meeting recordings	12 months after event date	None — deleted after retention	12 months	Event date + 12 months
Meeting transcripts	12 months after event date	None — deleted after retention	12 months	Event date + 12 months
Meeting minutes	Indefinite (association decides)	N/A	Until association deletes	Association admin action
Event data	Duration of association existence	12 months after association closure	Association lifetime + 12 months	Association closure + 12 months
Email notification logs	12 months	None	12 months	Send date + 12 months
Application logs	90 days (Application Insights)	9 months (cold storage)	1 year total	Log date + 1 year
Authentication logs	90 days (hot)	9 months (cold)	1 year total	Log date + 1 year
Security incident logs	1 year (hot)	2 years (cold)	3 years total	Incident date + 3 years
Consent records	Duration of relationship	3 years after relationship ends	Relationship + 3 years	Relationship end + 3 years
Backup data	30 days (rolling)	None — overwritten	30 days	Automatic rotation

6.2 Association-Level Data Lifecycle

When an association is closed or deactivated:

1. **Immediate:** Association marked as inactive; no new data processing
2. **30 days:** Admin notified of pending data deletion; option to export data
3. **60 days:** Non-financial member data anonymized or deleted
4. **12 months:** Event data, communications, and non-financial records deleted

5. **7 years:** Financial records retained for regulatory compliance, then deleted

6.3 Member-Level Data Lifecycle

When a member leaves an association or requests account deletion:

1. **Immediate:** Account deactivated; login access revoked
2. **30 days:** Personal data removed from active member lists and directories
3. **12 months:** Personal data deleted from primary systems
4. **Exception:** Financial transaction records retained for 7 years (anonymized where possible)
5. **Exception:** Meeting minutes referencing the member are retained (association's record) but personal identifiers can be redacted on request

---

7. Data Protection Controls

7.1 Encryption

Data in Transit:

Channel	Encryption	Standard
User ↔ Frontend	TLS 1.2+	HTTPS enforced, HSTS enabled
Frontend ↔ Backend API	TLS 1.2+	HTTPS only
Backend ↔ Database	TLS 1.2+	SSL enforced by Azure PostgreSQL
Backend ↔ Blob Storage	TLS 1.2+	HTTPS only
Backend ↔ Third-party APIs	TLS 1.2+	HTTPS only
Email delivery	TLS (opportunistic)	Provider-dependent

Data at Rest:

System	Encryption Method	Key Management
Azure PostgreSQL	Transparent Data Encryption (TDE)	Microsoft-managed keys
Azure Blob Storage	AES-256 Server-Side Encryption (SSE)	Microsoft-managed keys
Azure Key Vault	FIPS 140-2 Level 2 HSM-backed	Azure-managed
Database backups	AES-256	Microsoft-managed keys
Application secrets	Azure Key Vault encryption	RBAC-controlled access

7.2 Access Controls

- **Role-Based Access Control (RBAC)** at both application and infrastructure levels
- **Principle of least privilege** — users and systems access only what they need
- **Multi-factor authentication** required for all administrative access
- **Access reviews** conducted every 90 days
- **Audit logging** on all data access and modification events
- **Session management** — tokens expire (1-hour access, 7-day refresh)

7.3 Data Segregation

- Each association's data is logically segregated through `association_id` and `chapter_id` scoping
- API endpoints enforce data boundaries — members cannot access data from other associations
- Blob Storage follows path convention: `/{association_id}-{chapter_id}/{folder}/{year}/{month}/{day}/{file_name}`
- Database queries always filter by organization context

7.4 Anonymization and Pseudonymization

- Analytics and usage data are aggregated and anonymized before long-term storage
- When member data must be retained beyond the active period (e.g., financial records), personal identifiers are pseudonymized where possible
- Meeting transcripts can be redacted to remove personal identifiers on request

7.5 Data Loss Prevention

Control	Implementation
No public storage	Blob Storage containers are private; no anonymous access
SAS token expiry	Shared Access Signatures expire within 1 hour
No data in logs	PII and credentials are excluded from application logs
Secret scanning	GitHub Secret Scanning prevents credential exposure in source code
Input validation	All user inputs validated to prevent injection and data exfiltration
CORS restrictions	API only accepts requests from known frontend origins

---

8. Data Subject Rights

8.1 Rights Under NDPR/NDPA and GDPR

Right	Description	Process	Timeline
Right of Access	Members can request a copy of all personal data we hold about them	Submit request to support email; identity verified; data exported as JSON/CSV	30 days
Right to Rectification	Members can request correction of inaccurate or incomplete data	Submit request or update directly through account settings	30 days (or immediate via self-service)
Right to Erasure (Right to be Forgotten)	Members can request deletion of their personal data	Submit request; data deleted from active systems; retained only where legally required	30 days
Right to Restriction	Members can request limitation of processing of their data	Submit request; data marked as restricted; processing paused	30 days
Right to Data Portability	Members can request their data in a machine-	Submit request; data exported as JSON or CSV	30 days

	readable format		
Right to Object	Members can object to processing based on legitimate interest	Submit request; processing reviewed and ceased if no overriding interest	30 days
Right to Withdraw Consent	Members can withdraw consent at any time	Update preferences in account settings or submit request	Immediate (settings) / 30 days (request)

8.2 Request Process

1. **Submit:** Data subject sends request to support@transparencyhubnetwork.ai
2. **Verify:** Identity verified through account email confirmation
3. **Assess:** Request reviewed; determine scope and any legal exceptions
4. **Execute:** Request fulfilled (data exported, corrected, or deleted)
5. **Confirm:** Data subject notified of completion
6. **Log:** Request and outcome recorded in the data subject request register

8.3 Exceptions

Data subject requests may be partially denied when:

- Data retention is required by law (e.g., financial records for 7 years)
- Data is necessary for establishing, exercising, or defending legal claims
- Data has been anonymized and can no longer be linked to the individual
- The request is manifestly unfounded or excessive

Denial is communicated with explanation and information about the right to appeal.

---

9. Cross-Border Data Transfers

9.1 Data Locations

Data Type	Primary Location	Replication
Application data (database)	Azure South Africa North	Azure geo-redundant backup
File storage (recordings, documents)	Azure South Africa North	Azure geo-redundant storage
Meeting bot processing	Attendee.dev infrastructure (US)	N/A — transient processing
AI processing (Gemini)	Google Cloud (US/EU)	N/A — transient processing
Payment processing	Stripe (US/EU) / Paystack (Nigeria)	Provider-managed
Source code	GitHub (US)	N/A

9.2 Transfer Safeguards

When data is transferred outside Nigeria:

- Transfer is based on **adequate safeguards** as required by NDPA
- **Standard Contractual Clauses (SCCs)** or equivalent mechanisms in place with processors
- Third-party processors must demonstrate compliance with equivalent data protection standards

- Data processing agreements executed with all international processors
- Transfers are limited to the minimum data necessary for the service

9.3 Transient Processing

Meeting recordings and transcripts sent to Attendee.dev and Google Gemini are:

- Transmitted over encrypted channels (TLS 1.2+)
- Processed for the specific purpose (recording/transcription/minute generation)
- Not retained by the processor beyond the processing period
- Returned to our systems and stored in Azure (South Africa region)

---

10. Data Breach Response

10.1 Definition

A data breach is any incident that results in unauthorized access to, disclosure of, alteration of, loss of, or destruction of personal data.

10.2 Breach Classification

Level	Description	Examples
Critical	Large-scale exposure of Confidential or Restricted data	Database breach exposing member PII, payment data leaked, credentials compromised at scale
High	Limited exposure of Confidential data or system compromise	Single association's data accessed by unauthorized party, admin account compromised
Medium	Exposure of Internal data or near-miss incident	Logs containing limited PII exposed, misconfiguration allowing unauthorized API access (detected before exploitation)
Low	Minor data handling error with no confirmed exposure	Email sent to wrong recipient (non-sensitive content), data briefly accessible due to configuration change (corrected immediately)

10.3 Breach Response Timeline

Step	Action	Timeline
Detection	Identify and confirm the breach	Immediate
Containment	Stop the breach, preserve evidence	Within 4 hours
Assessment	Determine scope, affected data, affected individuals	Within 24 hours
Authority Notification	Notify NITDA (Nigeria) and/or relevant DPA	Within 72 hours of confirmation
Individual Notification	Notify affected individuals if high risk to rights/freedoms	Without undue delay (within 72 hours where possible)

Remediation	Fix root cause, restore systems	Based on severity SLA
Post-Incident Review	Root cause analysis, lessons learned, control updates	Within 5 business days

10.4 Breach Notification Content

Notifications to affected individuals include:

- Nature of the breach (what happened)
- Categories and approximate number of individuals affected
- Categories of personal data affected
- Likely consequences of the breach
- Measures taken to address the breach
- Measures individuals can take to protect themselves
- Contact information for questions (support@transparencyhubnetwork.ai)

10.5 Breach Register

All breaches (including near-misses) are recorded in a breach register with:

- Date and time of detection
- Description of the breach
- Data categories and volume affected
- Number of individuals affected
- Root cause
- Actions taken
- Notifications sent (authority, individuals)
- Remediation measures
- Lessons learned

---

11. Third-Party Data Processing

11.1 Processor Requirements

All third parties processing data on our behalf must:

Requirement	Details
Data Processing Agreement (DPA)	Executed before any data sharing begins
Security standards	Demonstrate equivalent security controls (SOC 2, ISO 27001, or documented equivalent)
Purpose limitation	Process data only for the specified purpose
Data minimization	Receive only the minimum data necessary
Breach notification	Notify us within 72 hours of any breach
Sub-processor transparency	Disclose sub-processors and obtain our approval
Data return/deletion	Return or delete data upon termination of agreement

Audit rights	Allow us to audit their data handling practices

11.2 Current Data Processors

Processor	Purpose	Data Shared	DPA Status	Compliance
Microsoft Azure	Cloud hosting and storage	All application data	Azure DPA	SOC 2, ISO 27001, GDPR
Attendee.dev	Meeting bot recording	Meeting URLs, scheduling metadata	In place	Security review completed
Google (Gemini AI)	Meeting minute generation	Meeting transcripts	Google Cloud DPA	SOC 2, ISO 27001
Stripe	Global payment processing	Transaction amounts, customer email	Stripe DPA	PCI DSS Level 1, SOC 2
Paystack	African payment processing	Transaction amounts, customer email	Paystack DPA	PCI DSS, NDPR compliant
GitHub	Source code and CI/CD	Source code (no user data)	GitHub DPA	SOC 2, ISO 27001

11.3 Processor Reviews

- Data processor compliance reviewed annually
- Processor security incidents monitored continuously
- DPAs reviewed on contract renewal or when processing changes
- Processors with repeated security issues are replaced

---

12. Data Protection by Design and Default

12.1 Design Principles

All new features and systems are designed with data protection built in:

- **Minimize:** Collect only necessary data
- **Segregate:** Isolate data by association and chapter
- **Encrypt:** Protect data at rest and in transit by default
- **Restrict:** Apply least-privilege access from the start
- **Log:** Record data access for accountability
- **Expire:** Set default retention periods; don't keep data forever
- **Delete:** Provide mechanisms for data deletion at every level

12.2 Default Settings

- **Privacy by default:** Most restrictive privacy settings applied automatically
- **Consent required:** Features requiring additional data processing require explicit opt-in
- **Recording off by default:** Meeting recording must be explicitly enabled per event
- **Data visibility scoped:** Members see only their own association's data

12.3 Data Protection Impact Assessment (DPIA)

A DPIA is conducted when:

- Introducing new processing of personal data at scale
- Processing special category data
- Implementing new surveillance or monitoring technologies
- Making significant changes to existing data processing
- Introducing cross-border data transfers to new jurisdictions

DPIA records are maintained and available for regulatory review.

---

13. Data Disposal

13.1 Disposal Methods

Storage Medium	Disposal Method	Verification
Database records	Secure deletion (SQL DELETE with cascade) or anonymization	Deletion confirmed via query
Blob Storage files	Soft delete (7-day recovery) → permanent deletion	Deletion confirmed via storage audit
Backups	Automatic overwrite per 30-day rolling cycle	Backup retention policy verified quarterly
Logs	Automatic expiry per retention settings	Retention settings audited quarterly
Development/test data	No production PII used in development; test data is synthetic	Quarterly verification
Physical media	N/A (cloud-only infrastructure)	N/A

13.2 Disposal Schedule

- Automated deletion jobs run daily to identify and process data past retention period
- Manual deletion requests processed within 30 days
- Disposal actions logged in the data management register
- Quarterly audit confirms disposal compliance

13.3 Certificate of Destruction

Upon request, we can provide confirmation that specific personal data has been deleted from all active systems. Note that data in rolling backups (30-day cycle) will be automatically overwritten within the backup retention window.

---

14. Training and Awareness

- All personnel complete data protection training upon onboarding
- Annual refresher training on data handling and privacy practices
- Role-specific training for personnel handling Restricted or Confidential data
- Training records maintained for compliance purposes
- Policy updates communicated to all personnel within 7 days of change

---

15. Monitoring and Compliance

15.1 Internal Audits

Audit	Frequency	Scope
Data retention compliance	Quarterly	Verify data is deleted per schedule
Access control review	Every 90 days	Review user permissions and access
Third-party processor review	Annually	Review DPAs and security posture
Data subject request compliance	Quarterly	Review request register and response times
Encryption and security controls	Quarterly	Verify encryption, key rotation, configurations

15.2 Metrics

Metric	Target
Data subject request response time	< 30 days (100% compliance)
Data retention compliance rate	> 99%
Breach notification time	< 72 hours
Personnel training completion	100%
Third-party DPA coverage	100%

---

16. Contact Information

Data Protection Enquiries: Email: support@transparencyhubnetwork.ai

Data Subject Requests: Email: support@transparencyhubnetwork.ai Subject line: "Data Subject Request — [Your Name]"

Security Incident Reporting: Email: security@transparencyhubnetwork.ai

---

17. Related Documents

Document	Description
Privacy Policy	Public-facing privacy notice (transparencyhubnetwork.ai/privacy)
Terms of Service	User agreement (transparencyhubnetwork.ai/terms-of-service)
Security Policy	Comprehensive security controls and practices
SSDLC	Secure Software Development Lifecycle
SAST & DAST	Application security testing documentation
Vulnerability Management Policy	Vulnerability identification and remediation

18. Document Control

Version	Date	Author	Changes
1.0	2026-03-05	Engineering Team	Initial version

This policy is reviewed and updated:

- **Annually** as a minimum
- **Quarterly** as part of the regular security review cycle
- **Immediately** following a data breach or significant regulatory change

---

For questions about this policy, contact: support@transparencyhubnetwork.ai